

GreenLeaf E-Commerce – PCI DSS v4.0.1 Gap Assessment

Prepared by: Cameron Naidoo | Date: 25 June 2026

1. Scope

This assessment covers GreenLeaf's e-commerce website, AWS backend, and the integration with the third-party payment processor (PaySecure). The scope is limited to the processing of cardholder data (CHD) during customer checkout

2. Key Requirement Review

Requirement 3: Protect Stored Account Data

- **Requirement:** 3.2 states: "Do not store sensitive authentication data after authorization (CVV/CVC codes)."
- **GreenLeaf Status: COMPLIANT** (Potentially). GreenLeaf does not actively store card numbers in its main database. However, a technical review of server access logs and cache memory is required to ensure CVV codes are not temporarily saved on the server side.
- **Action Required:** The CTO must configure the web server to exclude payment fields from error logs.

Requirement 8: Identify and Authenticate Access

- **Requirement:** 8.4 states: "Multi-factor authentication (MFA) must be implemented for all non-console administrative access."
- **GreenLeaf Status: NON-COMPLIANT.** This directly aligns with Risk GR-001. Admin accounts do not currently have MFA enforced.
- **Action Required:** Enforce MFA on all admin accounts (as documented in your Access Control Policy).

3. Vendor Dependency (PaySecure)

Since GreenLeaf outsources payment processing to PaySecure, GreenLeaf is also responsible for ensuring that PaySecure is PCI DSS compliant.

- **Status: UNCERTAIN.** During the vendor assessment (Project 2), PaySecure failed to provide a current SOC 2 or ISO 27001. GreenLeaf must formally request PaySecure's **Attestation of Compliance (AOC)** and **Responsibility Matrix** to close this gap.

4. Conclusion

GreenLeaf is **Partially Compliant** with PCI DSS. The biggest gap is the lack of MFA (GR-001) and the need to validate PaySecure's compliance. If an auditor arrives, GreenLeaf must produce evidence of MFA and a signed contract with PaySecure confirming their compliance status